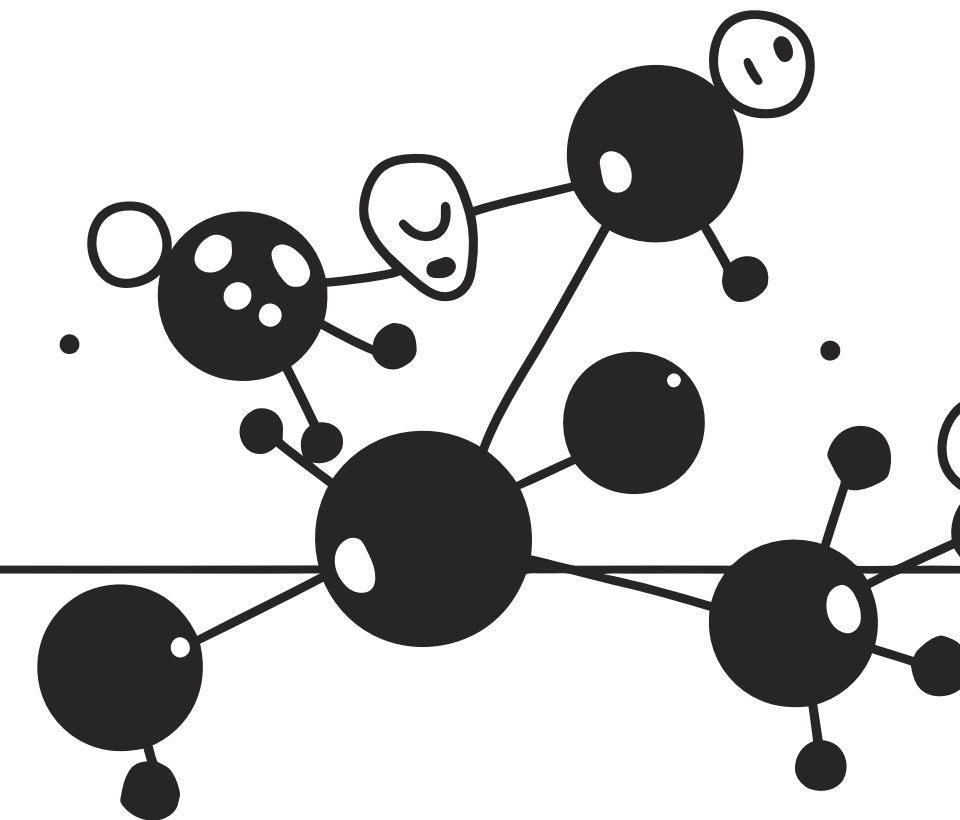
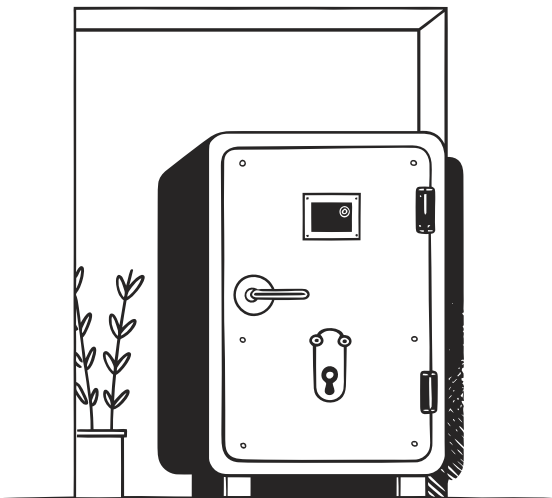




Teoria R4 · Protecció, consum i documentació d'API

Control d'accés, credencial didàctica, consumidor mínim i documentació executable — tot el que necessites per a **R4M3**, **R4M4** i **R4M5**.

Per què protegir una API?



Una API oberta sense criteri pot exposar dades sensibles o permetre accions no desitjades a qualsevol que conega l'endpoint.

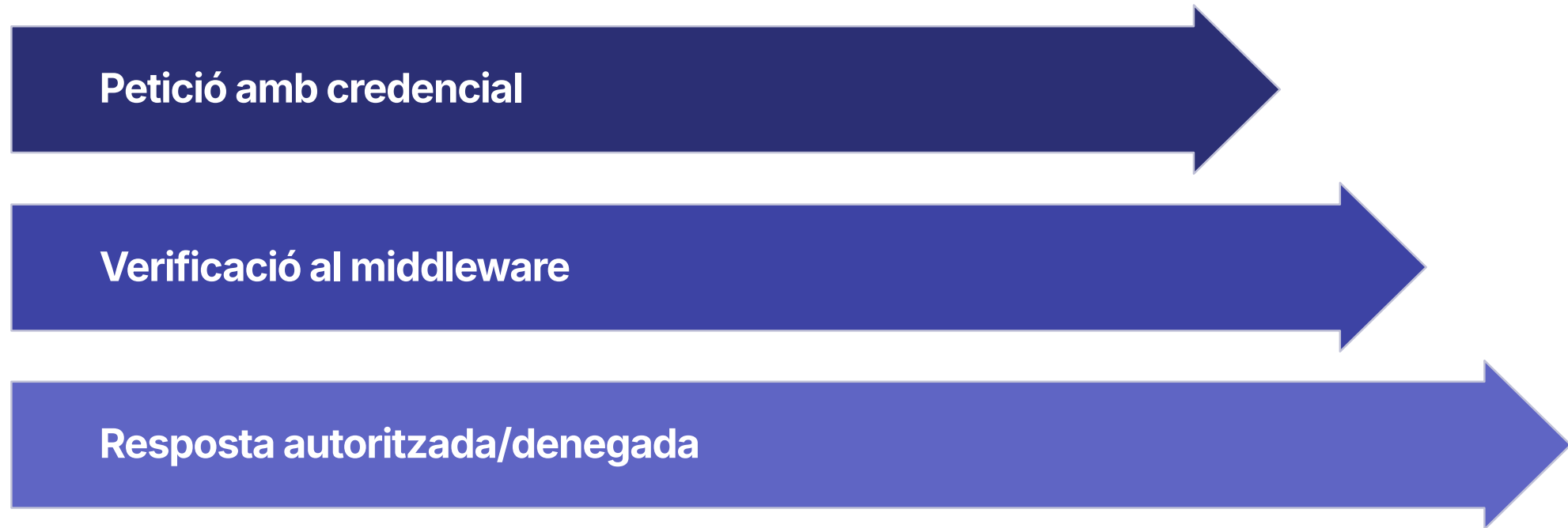
Sense protecció

Qualsevol pot llegir, modificar o esborrar recursos sense identificar-se.

Amb control d'accés

Només els consumidors autoritzats obtenen resposta. La resta rep un error clar.

Control d'accés en context d'API



El control d'accés no és el login web de R2 — és un mecanisme que valida cada petició de manera independent, sense sessió ni cookie.

La credencial didàctica

Per a R4 no cal OAuth ni JWT complex. N'hi ha prou amb una credencial senzilla que demostre el mecanisme.

Token a la capçalera

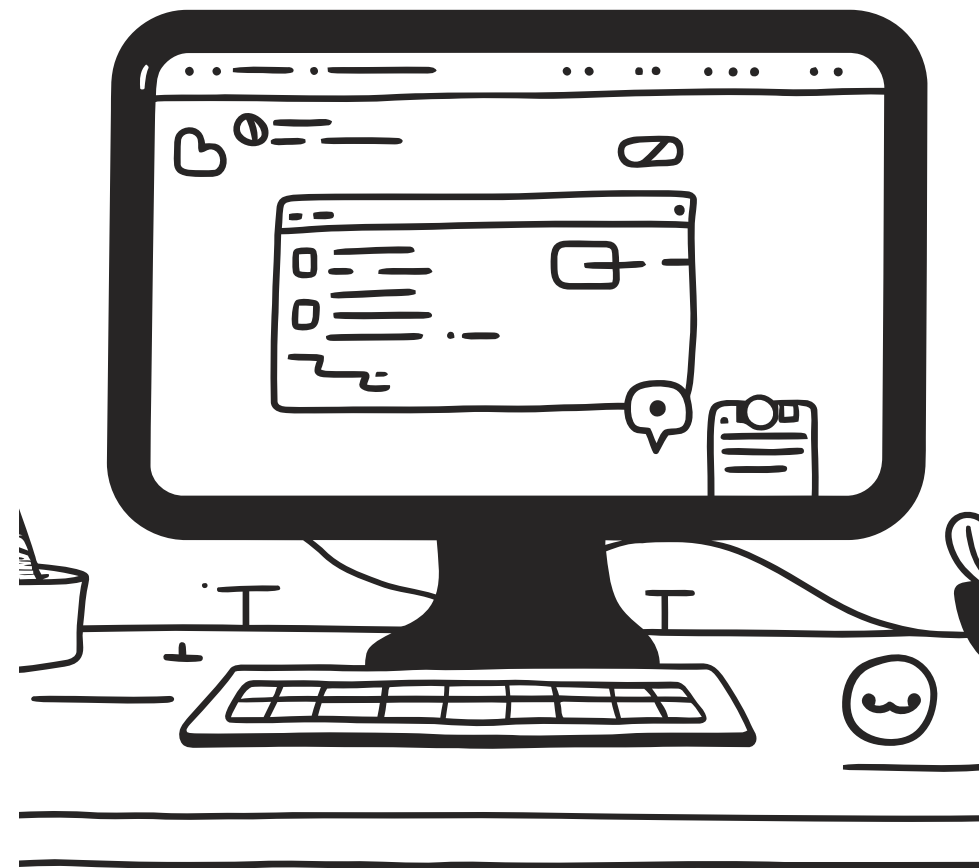
```
Authorization: Bearer abc123
```

Clau de consulta

```
?api_key=abc123
```

Capçalera personalitzada

```
X-API-Key: abc123
```



Cas autoritzat i cas denegat

El cas denegat és una **evidència obligatòria**: demostra que la protecció realment funciona i no és decorativa.

✓ Cas autoritzat

GET /api/articles

Authorization: Bearer abc123

Resposta: 200 OK amb el llistat de recursos.

✗ Cas denegat

GET /api/articles

(sense capçalera)

Resposta esperada: 401 Unauthorized o 403 Forbidden.

El consumidor mínim

Consumir una API implica actuar com un tercer independent. No cal una aplicació completa — n'hi ha prou amb qualsevol d'aquestes eines:



curl

Eina de línia de comandaments. Ideal per provar ràpidament qualsevol endpoint amb capçaleres i mètodes HTTP.



Script Python/JS

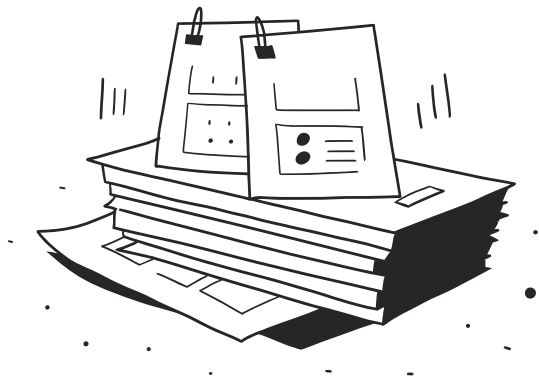
Un client mínim amb `fetch` o `requests` que envia la credencial i mostra la resposta per consola.



Postman / Insomnia

Clients gràfics que permeten guardar col·leccions de peticions i compartir-les com a documentació executable.

Documentació executable



La documentació ha de permetre que **una altra persona pugui repetir les peticions** sense demanar ajuda. Ha d'incloure:

⚠ Documentació bonica però no executable no és documentació — és decoració.

→ URL i mètode

Endpoint complet i verb HTTP: `POST /api/articles`

→ Capçaleres requerides

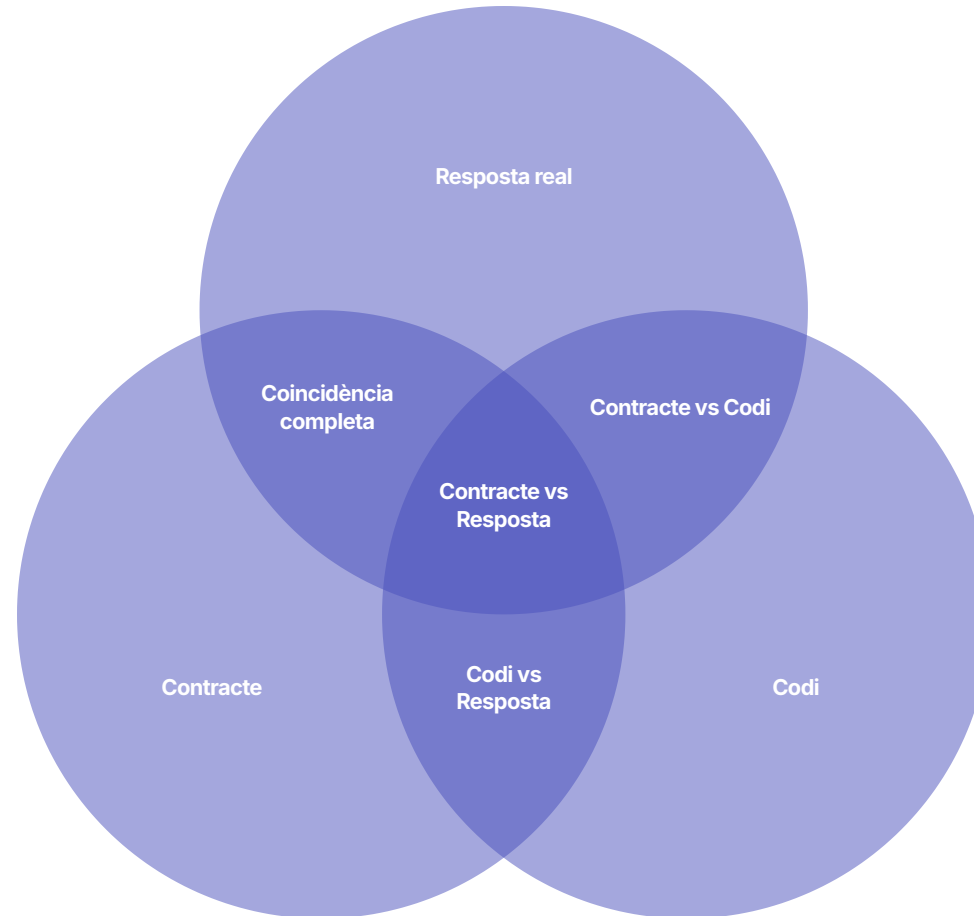
Quina credencial cal i on s'envia exactament.

→ Exemple de cos i resposta

JSON d'entrada i sortida esperada amb el codi d'estat.

Proves: contracte, codi i resposta real

Les proves han de contrastar tres elements. Si algun no coincideix, cal registrar la incidència i corregir-la.



Registre d'incidències

Anota qualsevol discrepància: codi d'estat incorrecte, camp absent, comportament inesperat.

Correcció documentada

Cada incidència ha de tenir la seua solució registrada: què es va canviar i per què.

Preguntes de comprovació

Abans de donar R4 per acabat, respon aquestes preguntes. Si no pots respondre-les totes, la feina no està completa.

01

Quina credencial necessita el consumidor?

Quin token, clau o capçalera cal enviar per accedir als recursos protegits?

02

Quina petició demostra el cas autoritzat?

Tens captura o log del 200 OK amb credencial correcta?

03

Quina petició demostra el cas denegat?

Tens evidència del 401 o 403 sense credencial?

04

Està documentat perquè algú altre ho pugui repetir?

La documentació és executable, no sols descriptiva?

05

La resposta real coincideix amb el contracte?

Camps, tipus i codis d'estat baten amb el que diu la documentació?